

ÉTUDE DE CAS — SPOTIFY

LIVRABLE 2

Politique de gouvernance des données et de l'IA

Certification RNCP 41993 – Adrien COSSON

Bloc 1 - Concevoir et piloter la gouvernance des données et des systèmes d'IA

1. Introduction

Le diagnostic de maturité (Livrable 1) a évalué la maturité de Spotify à environ 2,7 sur 5. L'entreprise exploite très bien ses données, mais elle n'a pas de cadre de gouvernance commun : selon le Business Case (BC), le marketing, le produit, le contenu et l'ingénierie « gèrent leurs propres jeux de données de façon indépendante ». Cela entraîne des silos, des problèmes de qualité et des difficultés à respecter les réglementations, comme l'a montré la sanction de l'autorité suédoise (IMY) en 2023.

Cette politique pose les règles communes à toute l'entreprise. Elle reprend les **quatre objectifs du business case** : améliorer la qualité des données, garantir la conformité réglementaire, protéger la vie privée des utilisateurs, et améliorer l'accessibilité et l'intégration des données. Chaque principe est relié aux défis (C1 à C7) identifiés dans le Livrable 1. Sa mise en œuvre concrète (pilote, outils, calendrier) est décrite dans le Livrable 3.

2. Périmètre et statut de la politique

La politique s'applique à **toutes les données** collectées ou traitées par Spotify, dans les plus de 180 pays où l'entreprise opère. Le business case cite notamment :

- Les journaux d'activité des utilisateurs (titres écoutés, playlists, recherches)
- Les métadonnées des titres et des podcasts
- Les données démographiques
- Les informations d'abonnement et de facturation

Elle couvre aussi les modèles d'IA qui utilisent ces données, à commencer par le moteur de recommandation.

Elle est validée par le Comité de gouvernance des données et s'impose à tous les collaborateurs. Elle est revue une fois par an, ou plus tôt en cas de changement réglementaire important.

3. Classification des données

La première règle de la politique est de classer chaque jeu de données selon sa sensibilité. Ce niveau est indiqué par une étiquette (tag) dans le Data Catalogue, et c'est elle qui détermine qui peut accéder à la donnée, combien de temps elle est conservée et si elle peut être partagée :

- **Public** : données visibles par tous (catalogue de titres, playlists publiques). Aucune restriction.
- **Interne** : données réservées aux collaborateurs (indicateurs agrégés, tableaux de bord). Accès libre en interne.
- **Confidentiel** : données personnelles des utilisateurs (historique d'écoute, données démographiques, segments marketing). Accès sur justification, données pseudonymisées pour les analyses, conservation limitée.
- **Restreint** : données les plus sensibles (données de facturation, données sensibles au sens du RGPD, données de mineurs). Accès nominatif et tracé, chiffrage obligatoire, aucun export sans l'accord du DPO.

4. Principes de gouvernance

Les neuf principes ci-dessous reprennent le Governance Principles Guide de Spotify. Pour chacun, la politique rappelle le constat du Livrable 1 auquel il répond et fixe une règle concrète, que l'on peut vérifier lors d'un audit.

Ils couvrent trois piliers : la qualité des données (principe 4), la sécurité (principe 3) et la conformité (principes 2, 5, 6 et 7), complétés par l'usage éthique de l'IA (principe 9). La redevabilité (principe 1) et l'amélioration continue (principe 8) s'appliquent à l'ensemble.

Principe 1 — Redevabilité (Accountability)

Définition : chaque processus lié aux données a un responsable clairement identifié.

Constat (C1, C3) : un CDO et un DPO existent, mais personne n'est responsable de chaque jeu de données : chaque département applique ses propres règles.

- **Règle appliquée** : chaque jeu de données critique a un Data Owner et un Data Steward nommés dans le Data Catalogue. Un jeu de données sans responsable ne peut pas être mis en production.

Principe 2 — Transparence (Transparency)

Définition : la collecte, le stockage et le partage des données personnelles sont clairement expliqués aux utilisateurs.

Constat (C2) : en 2023, l'IMY a sanctionné Spotify parce que ses réponses aux demandes d'accès étaient incomplètes et peu compréhensibles.

- **Règle appliquée** : des avis de confidentialité clairs et traduits dans la langue de l'utilisateur, une gestion du consentement centralisée, et des réponses aux demandes d'accès qui expliquent pour chaque donnée sa finalité, ses destinataires et sa durée de conservation.

Principe 3 — Sécurité des données (Data Security)

Définition : les données sensibles, notamment personnelles et de paiement, sont protégées selon les standards les plus élevés (PCI-DSS pour les paiements).

Constat (C5) : la sécurité repose sur le seul Head of Engineering (BC), alors que Spotify stocke des données de facturation.

- **Règle appliquée** : accès attribués par rôle (RBAC) et précisés selon l'étiquette de la donnée (ABAC), selon le principe du moindre privilège ; chiffrement des données Confidentielles et Restreintes ; revue des accès chaque trimestre ; protocole de réponse aux violations de données.

Principe 4 — Qualité des données (Data Quality)

Définition : les données collectées et traitées sont exactes, complètes et fiables.

Constat (C3, C4) : le BC cite des préférences utilisateurs erronées et des métadonnées obsolètes qui dégradent les recommandations ; il n'existe ni indicateurs de qualité partagés ni catalogue.

- **Règle appliquée** : chaque jeu de données partagé est décrit dans le Data Catalogue et accompagné d'un data contract, c'est-à-dire un document qui précise son contenu, ses définitions et ses seuils de qualité (complétude, exactitude, fraîcheur, doublons). Les contrôles sont automatisés et des audits de qualité sont réalisés régulièrement.

Principe 5 — Conformité (Compliance)

Définition : les traitements respectent le RGPD, le CCPA, PCI-DSS et les autres réglementations applicables.

Constat (C2) : Spotify opère dans plus de 180 pays aux règles différentes (BC), sans processus de conformité unifié.

- **Règle appliquée** : chaque traitement est inscrit au registre avec sa base légale ; une analyse d'impact (DPIA) est réalisée pour tout traitement à risque ; des audits de conformité ont lieu tous les six mois et une veille réglementaire est assurée (détails en section 5).

Principe 6 — Minimisation des données (Data Minimization)

Définition : seules les données nécessaires à une finalité précise sont collectées et traitées.

Constat (C1, C2) : les jeux de données sont dupliqués entre départements, ce qui multiplie les copies de données personnelles. Le BC demande explicitement des « stratégies de minimisation ».

- **Règle appliquée** : aucune nouvelle collecte sans finalité enregistrée ; une durée de conservation fixée pour chaque catégorie de données, avec suppression ou anonymisation automatique à son terme ; pseudonymisation par défaut pour les analyses.

Principe 7 — Droits des utilisateurs (User Rights)

Définition : les utilisateurs peuvent facilement accéder à leurs données, les modifier, les supprimer et s'opposer à leur collecte ou à leur vente.

Constat (C1, C2) : les données d'un même utilisateur sont réparties dans plusieurs silos, sans identifiant commun, ce qui rend les réponses incomplètes (motif de la sanction de 2023).

- **Règle appliquée** : tout système qui stocke des données personnelles doit être relié à l'identifiant utilisateur commun et permettre d'exporter et de supprimer ces données automatiquement. C'est une condition de mise en production. Les demandes sont traitées dans les délais légaux (1 mois pour le RGPD, 45 jours pour le CCPA).

Principe 8 — Amélioration continue (Continuous Improvement)

Définition : la gouvernance évolue avec la réglementation, les technologies et les besoins de Spotify.

Constat (C7) : la culture data est forte mais pas unifiée, et il n'existe pas de formation à la gouvernance.

- **Règle appliquée :** revue annuelle de la politique, indicateurs suivis chaque mois par le Comité, prise en compte des retours des équipes et formation de tous les collaborateurs.

Principe 9 — Usage éthique de l'IA (Ethical Use)

Définition : l'IA et les autres technologies fondées sur les données sont utilisées de manière transparente, respectueuse de la vie privée et surveillée contre les biais.

Constat (C6) : le BC demande de « prévenir les biais algorithmiques » et de rendre les systèmes d'IA « explicables », mais rien n'encadre aujourd'hui le moteur de recommandation.

- **Règle appliquée :** chaque modèle d'IA a un Model Owner et une fiche (finalité, données utilisées, niveau de risque au sens de l'AI Act). Avant chaque mise en ligne d'une nouvelle version du moteur de recommandation, on vérifie qu'il ne favorise pas certains contenus au détriment d'autres (par exemple les artistes très populaires face aux artistes émergents). Une supervision humaine est prévue, et les titres créés en tout ou partie par IA sont signalés dans leurs crédits.

5. Conformité réglementaire

Spotify étant établi en Suède, le **RGPD est retenu comme cadre de référence**. Lorsqu'un utilisateur relève de plusieurs lois, c'est la règle la plus protectrice qui s'applique. Les exigences ci-dessous reprennent la Compliance Checklist.

RGPD (Union européenne)

Exigences : traitement licite, loyal et transparent ; droits d'accès, de rectification et de suppression ; consentement explicite et éclairé ; notification des violations à l'autorité sous 72 heures ; désignation d'un Data Protection Officer (DPO).

- **Application chez Spotify :** registre des traitements relié au Data Catalogue ; traitement automatisé des demandes d'accès et de suppression (pilote du Livrable 3) ; plateforme de gestion du consentement avec preuve du consentement et retrait aussi simple que l'acceptation ; procédure de gestion des violations testée par des exercices ; DPO indépendant, rattaché à la direction générale.

CCPA / CPRA (Californie)

Exigences : mécanisme clair de refus de la vente des données (« Do Not Sell or Share ») ; droit d'accès et de suppression ; aucune discrimination envers un utilisateur qui exerce ses droits.

- **Application chez Spotify :** même chaîne de traitement des demandes que pour le RGPD, avec vérification d'identité ; transmission automatique du refus de l'utilisateur aux systèmes publicitaires ; vérification que les offres restent identiques pour tous.

PCI-DSS (données de paiement)

Exigences : réseau et systèmes sécurisés ; protection des données de carte ; gestion des vulnérabilités ; contrôle d'accès ; surveillance et tests réguliers ; politique de sécurité à jour.

- **Application chez Spotify :** les numéros de carte ne sont pas stockés par Spotify mais remplacés par un jeton (tokenisation) chez le prestataire de paiement, ce qui réduit fortement le périmètre concerné. Les données de facturation restantes sont classées « Restreint », chiffrées, et leur environnement est isolé, surveillé et testé régulièrement.

AI Act et autres réglementations

Exigences : l'AI Act impose de qualifier le niveau de risque de chaque système d'IA et d'informer les utilisateurs des contenus générés par IA. D'autres lois proches du RGPD s'appliquent selon les pays, comme le PDPA à Singapour cité dans le BC.

- **Application chez Spotify :** chaque modèle est qualifié par son Model Owner avec le DPO. Le moteur de recommandation n'est en principe pas « à haut risque », mais il est documenté et surveillé. La veille réglementaire est assurée par le DPO et l'équipe juridique, et les règles sont paramétrées par pays.

6. Organisation et responsabilités

Conformément au document Organizational Models et à la recommandation de l'Executive Q&A Guide, la gouvernance suit un modèle de Centre d'Excellence (CoE) : une équipe centrale définit les règles et fournit les outils, et chaque département reste responsable de ses données. Ce modèle concilie une gouvernance

cohérente et la souplesse nécessaire à chaque équipe ; il est détaillé dans l'organigramme (Livrable 2b). Comme le recommande ce même document, les rôles de gouvernance (CDO, Data Stewards) définissent les règles et contrôlent leur application, tandis que les rôles de gestion des données (Head of Engineering, Data Owners) les mettent en œuvre.

Les quatre premiers rôles reprennent le Data Governance Roles Template. Ils sont complétés par les parties prenantes citées dans le business case et par un rôle dédié à l'IA :

- **Chief Data Officer (CDO)** : pilote la stratégie de gouvernance, rapporte directement à la direction générale, définit les politiques en lien avec les objectifs métier et veille à leur alignement avec la direction.
- **Comité de gouvernance des données** : instance transverse qui réunit chaque mois des représentants des départements ; il valide les politiques, traite les sujets transverses entre départements et accorde les exceptions.
- **Data Protection Officer (DPO)** : garant de la conformité au RGPD et au CCPA, interlocuteur de l'IMY, conseille sur les DPIA et supervise la gestion des violations. Il est rattaché à la direction générale pour garantir son indépendance (RGPD).
- **Data Steward (dans chaque département)** : garantit l'exactitude, la cohérence et la fiabilité des données, travaille avec les équipes techniques pour améliorer la qualité, applique la politique et gère les accès.
- **Data Owner** : responsable des données d'un domaine ; il les classe et décide des accès. Ce rôle est confié aux responsables métier du BC, par exemple le Marketing Director pour les données marketing ou les Product Managers pour les données produit.
- **Head of Engineering (CIO/CTO)** : met en œuvre les contrôles techniques (sécurité, chiffrement, journalisation, intégration) et garantit une infrastructure conforme à la politique.
- **Équipe juridique** : valide les politiques, assure la veille réglementaire et encadre les contrats avec les sous-traitants.
- **Model Owner** : responsable d'un modèle d'IA sur tout son cycle de vie. Il documente l'origine des données d'entraînement et vérifie qu'elles peuvent être utilisées légalement. Il s'assure que les résultats du modèle sont reproductibles et explicables, vérifie l'absence de biais avant chaque mise en ligne et surveille ses performances en production. Ce rôle concerne le département Développement produit, qui porte le moteur de recommandation.

Matrice RACI

Chaque activité a un seul responsable final (A) et au moins un exécutant (R).

R = Réalise · A = Approuve et rend compte · C = Consulté · I = Informé

Activité	CDO	Comité	DPO	Owner	Steward	Head Eng.	Legal	Model Owner
Rédiger et valider la politique	R	A	C	C	C	C	C	I
Classifier un jeu de données et décider des accès	I		C	A	R	R		
Définir un data contract (qualité)	C			A	R	R		
Traiter une demande d'accès ou de suppression	I		A	C	R	R	C	
Réaliser une analyse d'impact (DPIA)	C		A	R	C	C	C	C
Gérer et notifier une violation (72 h)	I	I	A	C	I	R	R	
Documenter un modèle et vérifier ses biais	C		C	C		C		A/R
Auditer et réviser la politique	A/R	C	C	I	I	C	C	I
Qualifier le risque d'un modèle (AI Act)	C	I	A	C			C	R

7. Application et suivi de la politique

- **Exceptions** : une équipe qui ne peut pas respecter une règle doit en faire la demande motivée au Comité. L'exception est limitée à 6 mois et inscrite dans le Data Catalogue.
- **Non-respect** : le problème est remonté au Data Owner, puis au Comité. Un système qui ne respecte pas le principe 7 (droits des utilisateurs) ne peut pas être mis en production.
- **Mesure du succès** : comme le propose l'Executive Q&A Guide, la politique est évaluée sur quatre axes : la qualité (moins d'erreurs et de doublons), la conformité (aucune sanction, délai de réponse aux demandes), l'efficacité (accès plus rapide aux données) et la confiance des utilisateurs (moins de réclamations). Les indicateurs détaillés figurent dans le Livrable 3.

- **Sensibilisation** : un module de formation obligatoire pour tous, et des parcours adaptés aux Data Stewards, aux équipes techniques et aux équipes produit et marketing, comme le prévoit le BC (« training programs to educate employees on data governance policies »).

8. Conclusion

Cette politique donne à Spotify le cadre commun qui lui manquait. Elle repose sur les neuf principes du Governance Principles Guide, chacun traduit en une règle concrète et relié à un constat du diagnostic. Son idée centrale est simple : **chaque donnée a un responsable, une étiquette et un contrat**. Associée à une organisation claire et à une conformité intégrée dès la conception, elle permet de concilier l'innovation, qui fait la force de Spotify, avec la protection des utilisateurs. Cette politique n'est toutefois qu'un cadre : sa valeur dépendra de sa mise en œuvre, qui commence par un pilote présenté dans le Livrable 3.